



PROJET D'ETUDES 2023-2024

MASTER CYBERSECURITE

Création et mise en place d'un centre opérationnel de sécurité
(SOC)



Fait par l'étudiant Hamdy TABSISSI pour l'intervenant Nathan BRAMLI

SOMMAIRE

Table des matières

1. Introduction.....	3
A. Prestataire Externe : SUP DE VINCI	3
B. L'Entreprise : AudioProthèse+.....	3
C. Objectif du Projet	3
D. Normes et Règlements Applicables.....	4
2. Fonctionnement du Projet	4
A. Prérequis Techniques	4
B. L'architecture du SOC.....	6
C. Analyse des besoins et Mise en place des outils de sécurité	7
a. SIEM (Surveillance en continu) :.....	7
b. SOAR (Réponse aux incidents de sécurité) :.....	10
c. IPS/IDS (Détection des menaces) :	20
d. Mesures de prévention :	32
e. Rapports de sécurité :	33
f. Forensique.....	35
D. Formation des équipes de sécurité au maintien d'un SOC	37
3. Conclusion	38

1. Introduction

A. Prestataire Externe : SUP DE VINCI

AudioProthèse+ a opté pour SUP DE VINCI, une école d'informatique renommée spécialisée dans le numérique et la cybersécurité, pour la mise en place et l'exploitation de son Centre Opérationnel de Sécurité (SOC).

Avec son expertise avérée dans la conception et la gestion de SOC et son laboratoire de recherche dédié à la cybersécurité, SUP DE VINCI apporte une expertise technique et méthodologique de haut niveau. Leur équipe pédagogique, composée de professionnels expérimentés dans le domaine, assure une approche pragmatique et innovante, parfaitement alignée avec les besoins spécifiques d'AudioProthèse+.

Ce partenariat permet à AudioProthèse+ d'accéder à un SOC conforme aux meilleures pratiques du secteur, tout en bénéficiant d'un accompagnement durable et de qualité, favorisé par une collaboration étroite entre les deux entités tout au long du projet.

B. L'Entreprise : AudioProthèse+

AudioProthèse+, un réseau de centres d'audioprothèse présent dans plusieurs villes françaises, a pris l'initiative d'améliorer la sécurité de ses systèmes d'information en optant pour un centre opérationnel de sécurité (SOC) externalisé. Cette démarche permet à l'entreprise de bénéficier de l'expertise et des ressources spécialisées d'un fournisseur en sécurité informatique.

En externalisant son SOC, AudioProthèse+ peut non seulement concentrer ses efforts sur ses activités principales, mais aussi réaliser des économies significatives. Ces économies sont dues à l'élimination des coûts associés à l'établissement et à la gestion d'un SOC interne, assurant ainsi une protection efficace de ses données sans impacter son fonctionnement principal.

C. Objectif du Projet

Le projet envisagé par AudioProthèse+ vise à établir un centre opérationnel de sécurité (SOC) externalisé, afin d'assurer une protection accrue contre les menaces informatiques tout en optimisant les coûts. La démarche inclut plusieurs phases clés : l'analyse approfondie des besoins de sécurité spécifiques à l'entreprise, la conception d'une architecture adaptée pour le SOC, et la sélection rigoureuse d'outils de sécurité basés sur des projets Open Source. Un prestataire externe, spécialiste en sécurité informatique, sera sélectionné en collaboration avec le responsable de la sécurité d'AudioProthèse+.

Ce prestataire aura pour mission de mettre en place et de gérer le SOC, garantissant ainsi la sécurité des données personnelles conformément aux normes et réglementations telles que l'ISO/IEC 27001 et le RGPD.

Une attention particulière sera portée à la formation des équipes de sécurité sur les outils choisis. Ce projet s'inscrit dans une démarche d'amélioration continue de la sécurité, visant à répondre aux défis évolutifs de la sécurité informatique.

D. Normes et Règlements Applicables

L'ensemble des ouvrages demandés doit se conformer aux normes et règlements en vigueur, en suivant les bonnes pratiques qui reflètent l'état actuel de l'art. Il est important de souligner que, en cas de divergence entre les spécifications, la plus contraignante prévaudra. Les propositions de la Maîtrise d'Œuvre (MOE) doivent être en accord avec les clauses des lois, décrets, arrêtés, règlements, circulaires, normes, et tous les textes nationaux ou locaux pertinents à cette opération.

Parmi les documents applicables dans leur dernière édition, on trouve notamment la Loi no 78-17 du 6 janvier 1978, le Règlement européen 2016/679, connu sous le nom de RGPD, et la Directive 2016/1148, dite NIS. De plus, tous les travaux doivent répondre aux prescriptions techniques et fonctionnelles des textes normatifs ou documents techniques correspondants, incluant la famille de Normes ISO27000 avec son approche EBIOS-RM, ainsi que la famille de normes ISO31000.

Enfin, une attention particulière sera accordée à la sécurité applicative et à la souveraineté des données, avec une évaluation constante de la pertinence des préconisations de l'ANSSI en fonction des solutions techniques adoptées par la MOE.

2. Fonctionnement du Projet

A. Prérequis Techniques

Lors de la mise en place d'une plateforme SOC (Security Operations Center), il est crucial de considérer plusieurs éléments essentiels pour assurer son efficacité. Au cœur de cette plateforme, il faut une application de collecte centralisée capable de traiter et d'analyser en temps réel des données provenant de sources variées, comme les journaux d'événements, les données de pare-feu et les analyses de vulnérabilité. Cette application gère un volume conséquent de données et fournit des alertes de sécurité en cas d'incidents.

Un aspect fondamental est la persistance des données. La plateforme SOC stocke les informations de sécurité sur de longues périodes pour faciliter les analyses rétrospectives,

nécessitant ainsi des capacités de stockage adéquates et des processus de sauvegarde et de restauration fiables.

L'interface de gestion des alertes est également cruciale. Elle permet à l'équipe de sécurité de trier, prioriser et assigner les alertes par niveau de gravité, tout en étant conviviale et facile à utiliser pour une gestion efficace.

Par ailleurs, l'interface d'exploitation joue un rôle clé. Elle permet la configuration des paramètres de la plateforme, la surveillance des performances et la gestion des tâches de maintenance, tout en intégrant divers outils de sécurité et en automatisant certaines tâches.

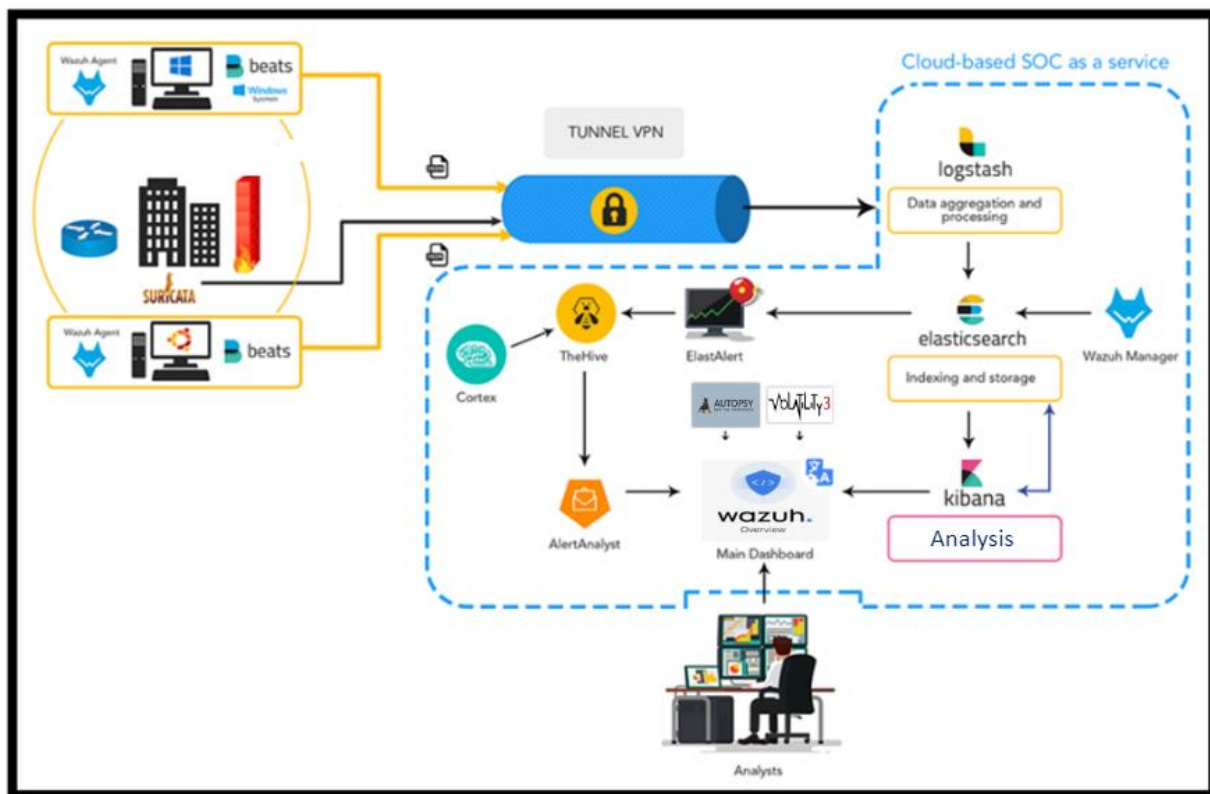
La sécurité des échanges entre les composants de la plateforme est primordiale. L'utilisation de protocoles de sécurité robustes est nécessaire pour chiffrer les communications et protéger les données.

Il est également important de définir des profils et privilèges utilisateurs spécifiques pour contrôler l'accès aux données et aux fonctionnalités de la plateforme, garantissant ainsi la sécurité et la conformité.

La gestion des logs est un autre aspect vital. Il y a des stratégies de rétention appropriées pour assurer la disponibilité et la sécurité des logs, indispensables pour les enquêtes et analyses futures.

Enfin, pour tester et évaluer les performances du SOC, l'utilisation d'un simulateur de données pour des attaques simulées et la création de jeux de test périodiques sont recommandées. Ces tests aident à maintenir et à améliorer la capacité du SOC à détecter et répondre efficacement aux menaces.

B. L'architecture du SOC



Ce schéma illustre l'infrastructure d'un Centre des Opérations de Sécurité (SOC) déployé dans le cloud, conçu pour surveiller et réagir aux menaces de cybersécurité en temps réel. En commençant par la collecte de données, des agents Wazuh sont installés sur des postes de travail pour rassembler des informations de sécurité, qui sont ensuite analysées par SURICATA, un système robuste de détection et de prévention des intrusions. Ces données sont transmises de manière sécurisée à travers un tunnel VPN, assurant l'intégrité et la confidentialité des informations sensibles.

Une fois dans le cloud, Logstash prend le relais pour l'agrégation et le traitement des données, avant qu'elles ne soient stockées et indexées par Elasticsearch. À ce stade, Wazuh Manager s'intègre dans le flux pour la gestion et l'orchestration des données de surveillance. Et est ensuite envoyé à Wazuh Dashboard offrant une interface d'analyse permettant de décortiquer et d'interpréter les données de manière intuitive.

Les anomalies ou les incidents détectés déclenchent des alertes via ElastAlert, qui sont ensuite coordonnées et gérées par TheHive, un outil spécialement conçu pour la réponse aux incidents de sécurité. Cortex pourrait être associé ici pour l'analyse avancée et l'enrichissement des alertes. Les analystes reçoivent ces alertes et interviennent au besoin, souvent en utilisant un tableau de bord principal qui centralise les informations et facilite la surveillance continue.

Les autres outils seront expliqués plus en détails au fil de ce rapport.

Cette architecture sécurisée et scalable permettra d'exploiter efficacement l'ensemble des fonctionnalités du SOC grâce à une visualisation centralisée et une automatisation poussée des tâches de sécurité. Elle garantira à AudioProthèse+ un niveau élevé de protection de ses systèmes d'information.

C. Analyse des besoins et Mise en place des outils de sécurité

Le SOC est chargé de la détection des menaces, de la réponse aux incidents de sécurité et de la mise en place de mesures de prévention pour protéger l'entreprise contre les attaques informatiques.

Le fonctionnement général pour le SOC externalisé sera le suivant.

a. SIEM (Surveillance en continu) :

Le SOC est capable de surveiller en temps réel les activités des systèmes d'information d'AudioProthèse+ et de détecter toute activité suspecte ou malveillante grâce au SIEM.

Le SIEM (Security Information and Event Management) est un outil essentiel pour le SOC, car il permet de collecter, corréler et analyser les données de sécurité provenant de différents systèmes et applications en détectant les activités suspectes ou malveillantes en temps réel et de fournir des alertes aux analystes de sécurité pour une réponse rapide.

Nous utilisons Wazuh pour assurer cette surveillance continue.

Wazuh est une solution de sécurité open source qui permet de superviser, détecter et répondre aux menaces grâce à une architecture SIEM.

Elle collecte les logs et événements de sécurité de manière centralisée depuis différentes sources comme les firewalls, les ENDPOINT ou les applications, puis les analyse à l'aide de moteurs de corrélation et de règles de détection d'anomalies.

Wazuh facilite la tâche des équipes SOC en leur fournissant une visibilité globale sur l'environnement grâce à son interface de supervision centralisée et ses capacités d'alerte en temps réel.

Après avoir installer Wazuh et vérifier qu'il était actif via ces commandes :

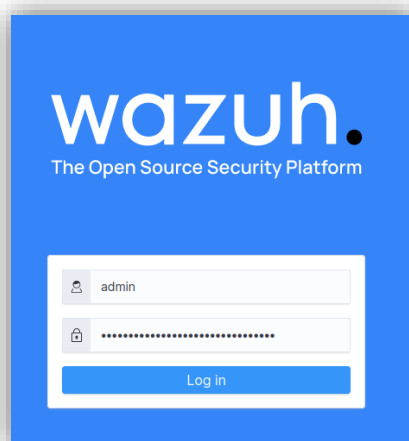
```
systemctl enable wazuh-manager  
systemctl start wazuh-manager
```



```
root@ubuntu:/home/ubuntu# systemctl status wazuh-manager
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enabled)
   Active: active (running) since Sun 2024-02-18 18:50:31 CET; 31min ago
     Tasks: 141 (limit: 7041)
    Memory: 209.3M
       CPU: 39.625s
   CGroup: /system.slice/wazuh-manager.service
           └─48645 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh-apid.py
           └─48685 /var/ossec/bin/wazuh-authd
           └─48701 /var/ossec/bin/wazuh-db
           └─48715 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh-apid.py
           └─48718 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh-apid.py
           └─48721 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh-apid.py
           └─48734 /var/ossec/bin/wazuh-execd
           └─48747 /var/ossec/bin/wazuh-analysisd
           └─48757 /var/ossec/bin/wazuh-syscheckd
           └─48822 /var/ossec/bin/wazuh-remoted
           └─48854 /var/ossec/bin/wazuh-logcollector
           └─48880 /var/ossec/bin/wazuh-monitord
           └─48927 /var/ossec/bin/wazuh-modulesd

févr. 18 18:50:23 ubuntu env[48585]: Started wazuh-db...
févr. 18 18:50:24 ubuntu env[48585]: Started wazuh-execd...
févr. 18 18:50:24 ubuntu env[48585]: Started wazuh-analysisd...
févr. 18 18:50:25 ubuntu env[48585]: Started wazuh-syscheckd...
févr. 18 18:50:26 ubuntu env[48585]: Started wazuh-remoted...
févr. 18 18:50:27 ubuntu env[48585]: Started wazuh-logcollector...
févr. 18 18:50:28 ubuntu env[48585]: Started wazuh-monitord...
févr. 18 18:50:29 ubuntu env[48585]: Started wazuh-modulesd...
févr. 18 18:50:31 ubuntu env[48585]: Completed.
févr. 18 18:50:31 ubuntu systemd[1]: Started Wazuh manager.
```

Nous pouvons accéder à l'interface graphique :



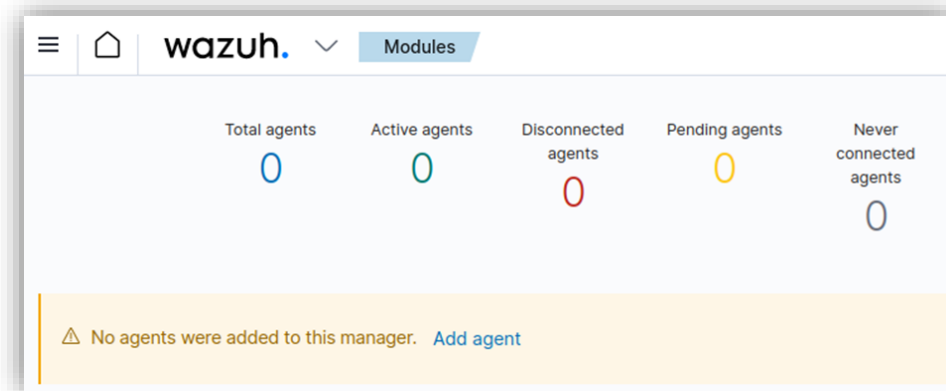
L'interface web de Wazuh permet de superviser et analyser de façon ergonomique les événements de sécurité détectés. Accessible via un navigateur, elle offre une vue centralisée sur l'ensemble des agents gérés.

Dans le dashboard, on peut visualiser en un coup d'œil les alertes critiques, le statut des agents, les dernières activités ou la répartition géographique. Des graphiques aident à identifier les tendances au niveau des vulnérabilités, intégrations ou sources d'alertes.

Un menu de gauche regroupe les principales fonctionnalités : la liste des agents permettant de lancer des commandes ou de consulter leur configuration ; la gestion des règles ID et de détection des anomalies ; l'analyse détaillée des alertes.

Pour chaque alerte, tous les détails sont disponibles : date, agent concerné, description, attributs, corrélations éventuelles. Il est possible de valider, ignorer ou marquer une alerte comme un faux positif depuis l'interface.

Cette interface conviviale offre une réelle valeur ajoutée pour simplifier la supervision au quotidien, faciliter l'investigation et le partage d'information entre les équipes techniques et de sécurité.



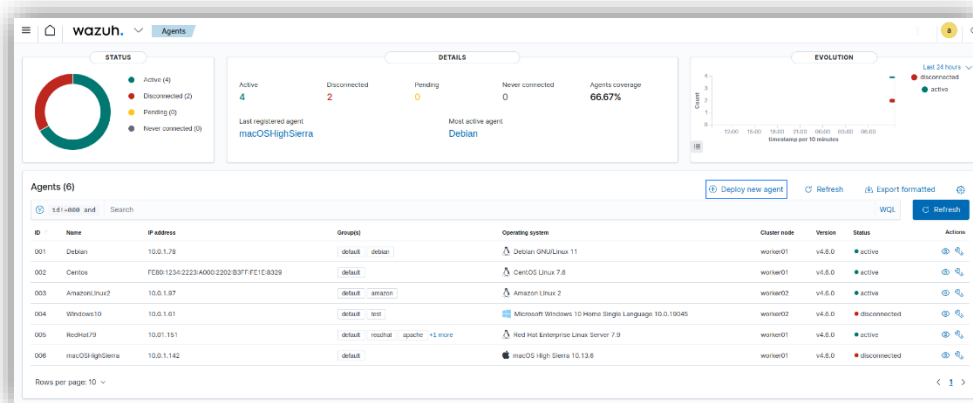
Les agents Wazuh sont des programmes installés sur chaque hôte devant être surveillé, qu'il s'agisse de serveurs physiques ou virtuels. Ils sont au cœur du système de détection d'intrusions Wazuh.

Chaque agent communique de manière sécurisée avec le manager central au moyen d'un certificat. Il analyse en continu les logs, fichiers et processus de son hôte à la recherche d'événements suspects.

Les agents Wazuh disposent de capacités de détection très poussées grâce à leur librairie Osquery qui leur permet d'interroger en profondeur le système. Ils analysent plus de 7000 indicateurs par défaut liés à l'intégrité des fichiers, la configuration du OS, les modifications dans les autorisations ou les tentatives d'escalade de privilèges.

En cas d'alerte déclenchée par la détection d'une anomalie, l'agent l'envoie immédiatement au manager central pour corrélation et traitement. Ce dernier supervise l'état de santé de tous les agents et peut déclencher des actions automatisées ou manuelles.

Grâce à cette architecture décentralisée, Wazuh assure une surveillance en temps réel et de bout en bout de l'ensemble du parc informatique supervisé.



L'installation des agents Wazuh se fait simplement sur chaque hôte à surveiller, que ce soit des serveurs physiques ou virtuels.

b. SOAR (Réponse aux incidents de sécurité) :

SOAR (Security Orchestration, Automation and Response) permet d'automatiser les processus de sécurité, de manière à réduire les temps de réponse aux incidents de sécurité et à augmenter l'efficacité de l'équipe de sécurité. Le SOAR peut être utilisé pour automatiser des tâches telles que la collecte de données de sécurité, l'analyse des événements de sécurité, la mise en place de mesures de prévention et la gestion des incidents.

Nous utiliserons TheHive.



TheHive est une solution open-source avancée de gestion des incidents de sécurité, conçue pour assister les analystes et les équipes de réponse aux incidents tels que les CERT et les CSIRT.

Elle se distingue par sa capacité à favoriser la collaboration en temps réel au sein des équipes, grâce à des fonctionnalités telles que l'assignation de tâches, le suivi de progression, et le partage d'informations critiques.

Elle offre également une intégration robuste avec divers outils de sécurité, automatisant ainsi des tâches répétitives et améliorant l'efficacité globale des processus de réponse aux incidents.

Nous allons installer TheHive via docker sur notre 2^{ème} serveur ubuntu : Server2Ubuntu

Docker permet d'accélérer le développement et le déploiement d'applications grâce à la containerisation. Un conteneur Docker isole une application et ses dépendances dans une image immuable qui peut ensuite être partagée et déployée identiquement sur tout environnement.



Plus exactement nous allons utiliser 'docker compose'.

Docker Compose est une extension de Docker qui permet de définir et de lancer des applications multi-conteneurs. Avec Compose, on écrit un fichier de configuration YAML qui définit les services qui composent notre application, ainsi que leurs dépendances les uns envers les autres.

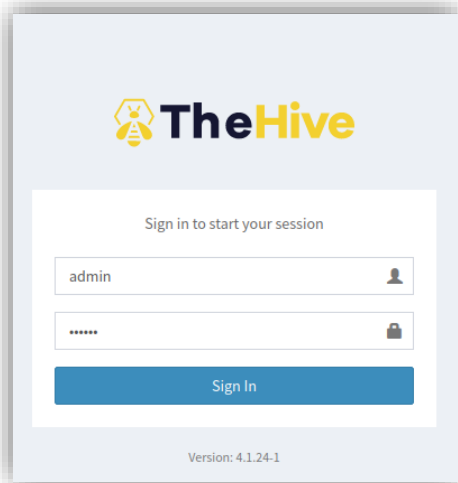
Ce fichier décrit à quoi ressemble notre application dans son ensemble :

```
version: '3'
services:
  elasticsearch:
    image: docker.elastic.co/elasticsearch/elasticsearch:7.12.1
    environment:
      - discovery.type=single-node
    volumes:
      - ./esdata:/usr/share/elasticsearch/data
    ports:
      - 9200:9200

  thehive:
    image: thehiveproject/thehive4:latest
    depends_on:
      - elasticsearch
    ports:
      - 9000:9000
    environment:
      - THEHIVE_DB_TYPE=elasticsearch
      - THEHIVE_DB_HOST=elasticsearch:9200
```

Qui permettra d'installer TheHive avec tous les paramètres voulue en une fois.

Voici la première page qui apparait apres l'installation :



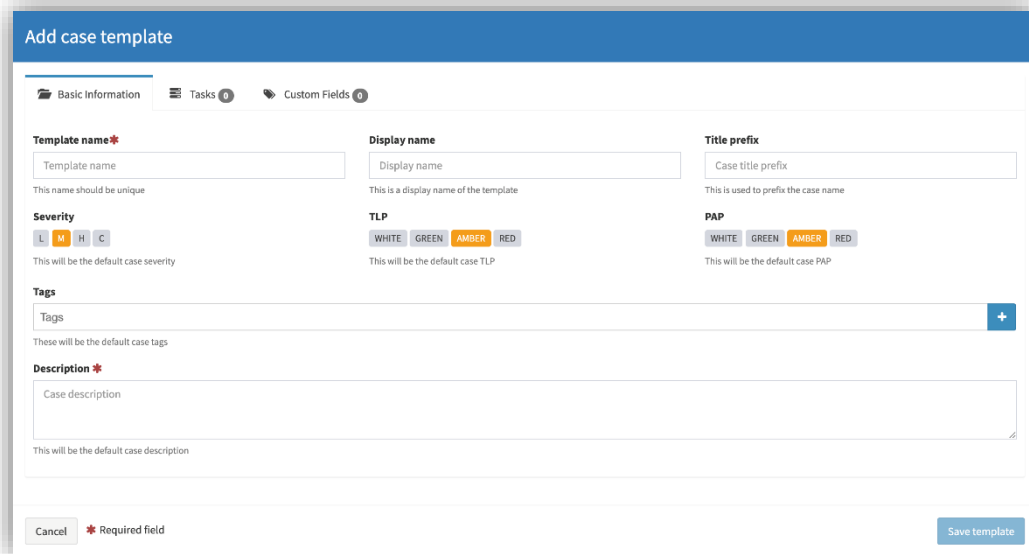
L'interface graphique de TheHive permet de gérer de manière ergonomique et visuelle les analyses et enquêtes en cours. Accessible via un navigateur web, elle offre une vue d'ensemble du workflow de réponse aux incidents de sécurité.

Dans le dashboard, l'utilisateur peut visualiser les tickets ouverts triés par statut (à traiter, en cours, résolus). Un clic permet d'accéder au détail d'un ticket et à sa timeline où s'affichent annotations, pièces jointes, actions effectuées.



Pour chaque ticket, il est possible de créer de nouvelles tâches à assigner aux analysts, de commenter les éléments collectés, d'analyser les observables grâce aux fonctionnalités intégrées comme le sandboxing ou le reverse lookup.

L'interface permet également de gérer des templates d'enquêtes, d'importer et exporter des tickets au format JSON, de configurer des workflows personnalisés ou d'administrer l'accès aux différents profils d'utilisateurs.

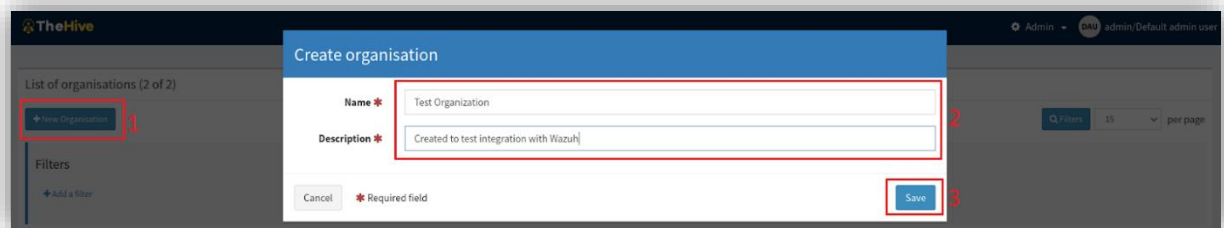


The screenshot shows the 'Add case template' form in TheHive. It has a blue header with the title 'Add case template'. Below the header are three tabs: 'Basic Information' (selected), 'Tasks', and 'Custom Fields'. The form contains several sections: 'Template name' with a text input and a note 'This name should be unique'; 'Display name' with a text input and a note 'This is a display name of the template'; 'Title prefix' with a text input and a note 'This is used to prefix the case name'; 'Severity' with a dropdown menu showing 'L', 'M', 'H', 'C' and a note 'This will be the default case severity'; 'TLP' with a dropdown menu showing 'WHITE', 'GREEN', 'AMBER', 'RED' and a note 'This will be the default case TLP'; 'PAP' with a dropdown menu showing 'WHITE', 'GREEN', 'AMBER', 'RED' and a note 'This will be the default case PAP'; 'Tags' with a text input and a '+' button, with a note 'These will be the default case tags'; and 'Description' with a text area and a note 'This will be the default case description'. At the bottom left are 'Cancel' and 'Required field' labels, and at the bottom right is a 'Save template' button.

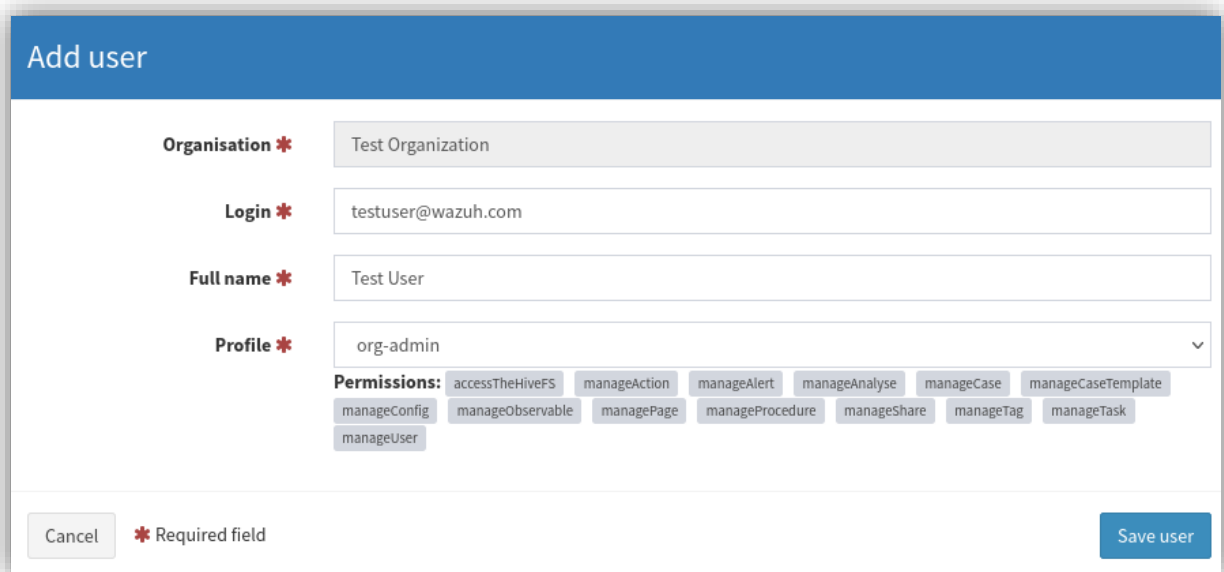
Après avoir découvert l'interface et ses fonctionnalités de TheHive, nous allons le connecter à Wazuh. L'intégration entre Wazuh et TheHive permet d'utiliser Wazuh comme source d'alertes/événements pour créer automatiquement des cas dans TheHive.



Nous créons une nouvelle organisation sur TheHive interface web et avec un compte administrateur.



Dans Test Organization, nous créons un nouvel utilisateur avec des privilèges d'administrateur d'organisation.



Cet utilisateur dispose d'autorisations pour gérer l'organisation, y compris la création de nouveaux utilisateurs, la gestion des cas et des alertes, entre autres.

Nous créons également un mot de passe pour cet utilisateur afin de pouvoir nous connecter pour afficher le tableau de bord et gérer les cas en cliquant sur « Nouveau mot de passe » à côté du compte d'utilisateur et entrez le mot de passe souhaité.

Status	Login ▲	Full Name ▼	Profile ▼	Password	API Key
Active	testuser@wazuh.com	Test User	org-admin	New password	Create API Key

L'intégration avec Wazuh est possible à l'aide de l'API REST Hive. Par conséquent, nous avons besoin d'un utilisateur sur TheHive qui peut créer des alertes via l'API. Nous créons un compte avec un privilège « analyste » à cette fin. L'intégration avec Wazuh est possible à l'aide de l'API REST Hive.

Par conséquent, nous avons besoin d'un utilisateur sur TheHive qui peut créer des alertes via l'API. Nous créons un compte avec un privilège « analyste » à cette fin.

Add user

Organisation * Test Organization

Login * thehive.api@wazuh.com

Full name * API User

Profile * analyst

Permissions: accessTheHiveFS, manageAction, manageAlert, manageAnalyse, manageCase, manageObservable, managePage, manageProcedure, manageShare, manageTask

Cancel * Required field Save user

Pour l'étape suivante, nous générons la clé API pour l'utilisateur :

Create API key

Are you sure you want to create a new API key for this user?

Cancel Yes, create it 2

User List (2 of 2)

Status	Login	Full Name	Profile	Password	API Key	MFA	Dates C. & U.
Active	testuser@wazuh.com	Test User	org-admin	Edit password	Create API Key	No	C. 03/14/22 13:43 U. 03/14/22 14:17
Active	thehive.api@wazuh.com	API User	analyst	New password	Create API Key 1	No	C. 03/14/22 14:19 U. 03/14/22 14:22

Afin d'extraire la clé API, nous révélons la clé à afficher et à copier pour une utilisation future

Status	Login	Full Name	Profile	Password	API Key	MFA	Dates C. & U.
Active	testuser@wazuh.com	Test User	org-admin	Edit password	Create API Key	No	C. 03/14/22 13:43 U. 03/14/22 14:17
Active	thehive.api@wazuh.com	API User	analyst	New password	Renew Reveal RfHeY0yE0iRnd3m3o302z5LudKQYTM	No	C. 03/14/22 14:19 U. 03/14/22 14:22

Pour ce qui est de la configuration sur TheHive c'est fini, nous allons du côté de Wazuh Manager.

Tout d'abord, nous installons le module Python Hive :

```
sudo /var/ossec/framework/python/bin/pip3 install thehive4py==1.8.1
```

Nous créons le script d'intégration personnalisé en collant le code python suivant dans /var/ossec/integrations/custom-w2thive.py.

La variable lvl_threshold dans le script indique le niveau d'alerte minimum qui sera transféré à TheHive.

La variable peut être personnalisée de sorte que seules les alertes pertinentes soient transmises à TheHive :

```
#!/var/ossec/framework/python/bin/python3
import json
import sys
import os
import re
import logging
import uuid
from thehive4py.api import TheHiveApi
from thehive4py.models import Alert, AlertArtifact
#start user config
# Global vars
#threshold for wazuh rules level
lvl_threshold=0
#threshold for suricata rules level
suricata_lvl_threshold=3
debug_enabled = False
#info about created alert
info_enabled = True
#end user config
# Set paths
pwd = os.path.dirname(os.path.dirname(os.path.realpath(__file__)))
log_file = '{0}/logs/integrations.log'.format(pwd)
logger = logging.getLogger(__name__)
#set logging level
logger.setLevel(logging.WARNING)
if info_enabled:
    logger.setLevel(logging.INFO)
if debug_enabled:
    logger.setLevel(logging.DEBUG)
# create the logging file handler
fh = logging.FileHandler(log_file)
formatter = logging.Formatter('%(asctime)s - %(name)s - %(levelname)s - %(message)s')
fh.setFormatter(formatter)
logger.addHandler(fh)
def main(args):
    logger.debug('#start main')
    logger.debug('#get alert file location')
    alert_file_location = args[1]
```

```

logger.debug('#get TheHive url')
thive = args[3]
logger.debug('#get TheHive api key')
thive_api_key = args[2]
thive_api = TheHiveApi(thive, thive_api_key )
logger.debug('#open alert file')
w_alert = json.load(open(alert_file_location))
logger.debug('#alert data')
logger.debug(str(w_alert))
logger.debug('#gen json to dot-key-text')
alt = pr(w_alert,",[ ]")
logger.debug('#formatting description')
format_alt = md_format(alt)
logger.debug('#search artifacts')
artifacts_dict = artifact_detect(format_alt)
alert = generate_alert(format_alt, artifacts_dict, w_alert)
logger.debug('#threshold filtering')
if w_alert['rule']['groups']==['ids','suricata']:
    #checking the existence of the data.alert.severity field
    if 'data' in w_alert.keys():
        if 'alert' in w_alert['data']:
            #checking the level of the source event
            if int(w_alert['data']['alert']['severity'])<=suricata_lvl_threshold:
                send_alert(alert, thive_api)
    elif int(w_alert['rule']['level'])>=lvl_threshold:
        #if the event is different from suricata AND suricata-event-type: alert check lvl_threshold
        send_alert(alert, thive_api)
def pr(data,prefix, alt):
    for key,value in data.items():
        if hasattr(value,'keys'):
            pr(value,prefix+'.'+str(key),alt=alt)
        else:
            alt.append((prefix+'.'+str(key)+' | | '+str(value)))
    return alt
def md_format(alt,format_alt=""):
    md_title_dict = {}
    #sorted with first key
    for now in alt:
        now = now[1:]
        #fix first key last symbol
        dot = now.split(' | | ')[0].find('.')
        if dot==-1:
            md_title_dict[now.split(' | | ')[0]] =[now]
        else:
            if now[0:dot] in md_title_dict.keys():
                (md_title_dict[now[0:dot]]).append(now)
            else:
                md_title_dict[now[0:dot]]= [now]
    for now in md_title_dict.keys():
        format_alt+=### '+now.capitalize()+'\n'+ ' | key | val | \n | ----- | ----- | \n'
    for let in md_title_dict[now]:
        key,val = let.split(' | | ')[0],let.split(' | | ')[1]

```

```

        format_alt+='| **' + key + '** | ' + val + ' |\n'
    return format_alt
def artifact_detect(format_alt):
    artifacts_dict = {}
    artifacts_dict['ip'] = re.findall(r'\d+\.\d+\.\d+\.\d+',format_alt)
    artifacts_dict['url'] = re.findall(r'http[s]?://(?:[a-zA-Z]|[0-9]|[$-_@.&+]|[*\(\),]|(?:%[0-9a-fA-F][0-9a-fA-F]))+',format_alt)
    artifacts_dict['domain'] = []
    for now in artifacts_dict['url']: artifacts_dict['domain'].append(now.split('/')[1].split('/')[0])
    return artifacts_dict
def generate_alert(format_alt, artifacts_dict,w_alert):
    #generate alert sourceRef
    sourceRef = str(uuid.uuid4())[0:6]
    artifacts = []
    if 'agent' in w_alert.keys():
        if 'ip' not in w_alert['agent'].keys():
            w_alert['agent']['ip']='no agent ip'
        else:
            w_alert['agent'] = {'id':'no agent id', 'name':'no agent name'}
    for key,value in artifacts_dict.items():
        for val in value:
            artifacts.append(AlertArtifact(dataType=key, data=val))
    alert = Alert(title=w_alert['rule']['description'],
        tlp=2,
        tags=['wazuh',
            'rule='+w_alert['rule']['id'],
            'agent_name='+w_alert['agent']['name'],
            'agent_id='+w_alert['agent']['id'],
            'agent_ip='+w_alert['agent']['ip'],],
        description=format_alt ,
        type='wazuh_alert',
        source='wazuh',
        sourceRef=sourceRef,
        artifacts=artifacts,)
    return alert
def send_alert(alert, thive_api):
    response = thive_api.create_alert(alert)
    if response.status_code == 201:
        logger.info('Create TheHive alert: ' + str(response.json()['id']))
    else:
        logger.error('Error create TheHive alert: {}/{}'.format(response.status_code, response.text))
if __name__ == "__main__":
    try:
        logger.debug('debug mode') # if debug enabled
        # Main function
        main(sys.argv)
    except Exception:
        logger.exception('EGOR')

```

Nous créons un script bash en tant que /var/ossec/integrations/custom-w2thive. Cela exécutera correctement le script.py créé à l'étape précédente :

```
#!/bin/sh
# Copyright (C) 2015-2020, Wazuh Inc.
# Created by Wazuh, Inc. <info@wazuh.com>.
# This program is free software; you can redistribute it and/or modify it
# under the terms of GP>

WPYTHON_BIN="framework/python/bin/python3"

SCRIPT_PATH_NAME="$0"

DIR_NAME="$(cd $(dirname ${SCRIPT_PATH_NAME}); pwd -P)"
SCRIPT_NAME="$(basename ${SCRIPT_PATH_NAME})"

case ${DIR_NAME} in
    */active-response/bin | */wodles*)
        if [ -z "${WAZUH_PATH}" ]; then
            WAZUH_PATH="$(cd ${DIR_NAME}/../..; pwd)"
        fi

        PYTHON_SCRIPT="${DIR_NAME}/${SCRIPT_NAME}.py"
        ;;
    */bin)
        if [ -z "${WAZUH_PATH}" ]; then
            WAZUH_PATH="$(cd ${DIR_NAME}/..; pwd)"
        fi

        PYTHON_SCRIPT="${WAZUH_PATH}/framework/scripts/${SCRIPT_NAME}.py"
        ;;
    */integrations)
        if [ -z "${WAZUH_PATH}" ]; then
            WAZUH_PATH="$(cd ${DIR_NAME}/..; pwd)"
        fi

        PYTHON_SCRIPT="${DIR_NAME}/${SCRIPT_NAME}.py"
        ;;
esac

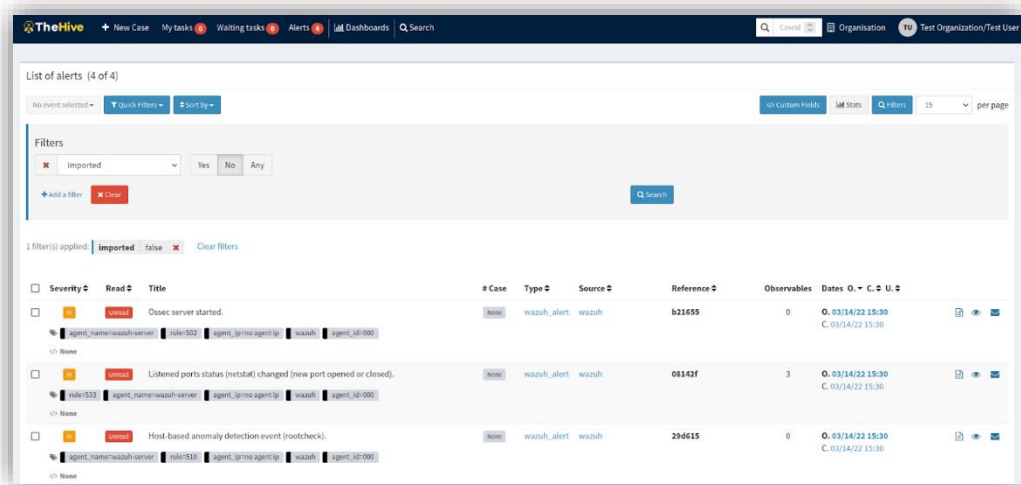
${WAZUH_PATH}/${WPYTHON_BIN} ${PYTHON_SCRIPT} $@
```

Pour permettre à Wazuh d'exécuter le script d'intégration, Nous insérons l'adresse IP du serveur TheHive avec la clé API générée précédemment au fichier de configuration du gestionnaire situé à /var/ossec/etc/ossec.conf.

Redémarrer le gestionnaire pour appliquer les modifications :

```
sudo systemctl restart wazuh-manager
```

Nous pouvons voir les alertes générées par Wazuh sous l'onglet « Alertes » :



c. IPS/IDS (Détection des menaces) :

En cas d'activité suspecte, le SOC sera en mesure de l'analyser et de déterminer s'il s'agit d'une menace potentielle pour les systèmes d'information d'AudioProthèse+.

Les IDS/IPS (Intrusion Detection/Prevention System) sont des outils qui permettent de surveiller en temps réel les flux de données et de détecter toute tentative d'intrusion ou d'attaque sur le réseau. Les IDS/IPS peuvent également bloquer les attaques en temps réel, en appliquant des règles de sécurité spécifiques.

Le SOC utilisera Suricata pour analyser les alertes et déterminer les menaces potentielles.

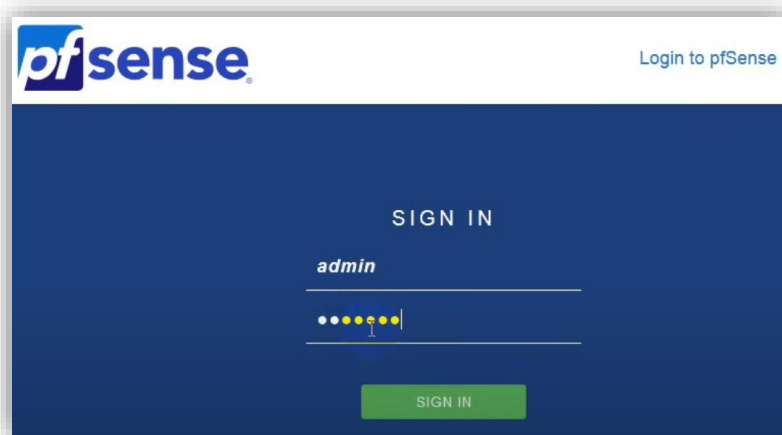
Suricata est une solution open source de détection et de prévention des intrusions réseau (IDS/IPS). Elle permet d'analyser en profondeur le trafic réseau afin d'identifier une grande variété de menaces telles que les attaques par déni de service, les exploits, les cyberattaques avancées, etc.

Parmi ses principales fonctionnalités, Suricata permet la détection d'intrusion réseau (IDS), la prévention d'intrusion (IPS), l'analyse en temps réel du trafic, la journalisation centralisée des événements, ou encore le décodage de protocoles complexes comme HTTP, SSL/TLS ou DNS.

Tout d'abord avant d'installer Suricata, nous commencerons par installer le pfSense.

Le pfSense est un système d'exploitation (OS) spécialisé, conçu principalement pour être utilisé comme un pare-feu et un routeur. À bien des égards, il est similaire à d'autres systèmes d'exploitation comme Ubuntu, en ce sens qu'il peut être installé sur du matériel physique ou déployé en tant que machine virtuelle. Cependant, contrairement à Ubuntu, qui est un OS généraliste orienté vers une variété d'utilisations, pfSense est spécifiquement optimisé pour la sécurité réseau et la gestion du trafic.

Une fois installé et que l'on a accès à l'interface graphique :

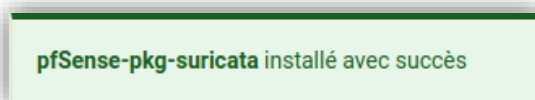


Cette interface permet de configurer des fonctionnalités avancées de pare-feu, de VPN, de NAT, de DHCP, et bien d'autres encore.

Nous passons à l'installation de Suricata, pour ce faire, nous allons dans Système, Gestionnaire de paquets et enfin Paquets disponibles pour rechercher 'suricata' :



Suricata est maintenant disponible dans Services puis Suricata :



Ensuite, nous allons nous rendre dans Global Settings et on renseigne :

- Install ETOpen Emerging Threats rules : cocher la case ETOpen...
- Install Snort GPLv2 Community rules : The Snort...
- Update Interval : 1 Day
- Update Start Time : l'heure de vous voulez
- GeoLite2 DB Update : cocher si vous avez un compte sur le site MaxMind (la création du compte et l'utilisation de DB est gratuite)
- GeoLite2 DB License Key : numéro de license

Les autres options peuvent être laissées par défaut. Il ne reste plus qu'à enregistrer.

Please Choose The Type Of Rules You Wish To Download

Install ETOpen Emerging Threats rules ☒ ETOpen is a free open source set of Suricata rules whose coverage is more limited than ETPro. ☐ Use a custom URL for ETOpen downloads

Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETOpen rules.

Install ETPro Emerging Threats rules ☐ ETPro for Suricata offers daily updates and extensive coverage of current malware threats. ☐ Use a custom URL for ETPro rule downloads

The ETPro rules contain all of the ETOpen rules, so the ETOpen rules are not required and are disabled when the ETPro rules are selected. [Sign Up for an ETPro Account](#). Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETPro rules.

ETPro Subscription Configuration Code

Obtain an ETPro subscription code and paste it here.

Install Snort rules ☐ Snort free Registered User or paid Subscriber rules ☐ Use a custom URL for Snort rule downloads

[Sign Up for a free Registered User Rules Account](#)
[Sign Up for paid Snort Subscriber Rule Set \(by Talos\)](#)

Enabling the custom URL option will force the use of a custom user-supplied URL when downloading Snort Subscriber rules.

Install Snort GPLv2 Community rules ☒ The Snort Community Ruleset is a GPLv2 Talos-certified ruleset that is distributed free of charge without any Snort Subscriber License restrictions. ☐ Use a custom URL for Snort GPLv2 rule downloads

This ruleset is updated daily and is a subset of the subscriber ruleset. If you are a Snort Subscriber Rules customer (paid subscriber), the community ruleset is already built into your download of the Snort Subscriber rules, and there is no benefit in adding this rule set separately.

Hide Deprecated Rules Categories ☐ Hide deprecated rules categories in the GUI and remove them from the configuration. Default is Not Checked.

Rules Update Settings

Update Interval

Please select the interval for rule updates. Choosing NEVER disables auto-updates.

Hint: In most cases, every 12 hours is a good choice.

Update Start Time

Enter the rule update start time in 24-hour format (HH:MM). Default is 00 hours with a randomly chosen minutes value. Rules will update at the interval chosen above starting at the time specified here. For example, using a start time of 00:08 and choosing 12 Hours for the interval, the rules will update at 00:08 and 12:08 each day. The randomized minutes value should be retained to minimize the impact to the rules update site from large numbers of simultaneous requests.

Live Rule Swap on Update ☐ Enable 'Live Swap' reload of rules after downloading an update. Default is Not Checked

When enabled, Suricata will perform a live load of the new rules following an update instead of a hard restart. If issues are encountered with live load, uncheck this option to perform a hard restart of all Suricata instances following an update.

GeoLite2 DB Update ☒ Enable downloading of free GeoLite2 Country IP Database updates. Default is Not Checked

When enabled, Suricata will automatically download updates for the free GeoLite2 country IP database.

If you have a subscription for more current GeoIP2 updates, uncheck this option and instead create your own process to place the required database file in `/usr/local/share/suricata/GeoLite2/`.

GeoLite2 DB License Key

To utilize the free MaxMind GeoLite2 GeoIP functionality, you must [register for a free MaxMind user account](#). Use the GeoIP Update version 3.1.1 or newer registration option.

Paramètres généraux

Remove Blocked Hosts Interval

Please select the amount of time you would like hosts to be blocked. Note this setting is only applicable when using Legacy Mode blocking! This setting is ignored when using Inline IPS Mode.

Hint: in most cases, 1 hour is a good choice.

Log to System Log ☐ Copy Suricata messages to the firewall system log.

Keep Suricata Settings After Deinstall ☒ Settings will not be removed during package deinstallation.

Ensuite dans Logs Mgmt, c'est ici, que nous pouvons gérer les logs. Pour cet article, je laisse la configuration par défaut mais pour des besoins légaux, elle peut être à modifier.

Paramètres généraux

Remove Suricata Logs On Package Uninstall

☐ Suricata log files will be removed when the Suricata package is uninstalled. Default is not checked.

Auto Log Management

☒ Enable automatic unattended management of Suricata logs using parameters specified below. Default is checked.

Log Directory Size Limit

Log Directory Size Limit

☐ Enable Directory Size Limit

Log Limit Size in MB

2494

This setting imposes a hard-limit on the combined log directory size of all Suricata interfaces. When the size limit set is reached, rotated logs for all interfaces will be removed, and any active logs pruned to zero-length. (default is 20% of available free disk space)

Log Size and Retention Limits

alert	300 KB	14 DAYS	Max Size. Default is 300 KB. Suricata alerts and event details	Retention. Default is 14 DAYS.
block	300 KB	14 DAYS	Max Size. Default is 300 KB. Suricata blocked IPs and event details	Retention. Default is 14 DAYS.
eve-json	5 MB	7 DAYS	Max Size. Default is 5 MB. Eve-JSON (JavaScript Object Notation) data	Retention. Default is 7 DAYS.
files-json	1 MB	7 DAYS	Max Size. Default is 1 MB. Captured files info in JSON format	Retention. Default is 7 DAYS.
http	1 MB	7 DAYS	Max Size. Default is 1 MB. Captured HTTP events and session info	Retention. Default is 7 DAYS.
sid_changes	250 KB	14 DAYS	Max Size. Default is 250 KB. Log of SID changes made by SID Mgmt conf files	Retention. Default is 14 DAYS.
stats	300 KB	7 DAYS	Max Size. Default is 300 KB. Suricata performance statistics	Retention. Default is 7 DAYS.
tls	300 KB	14 DAYS	Max Size. Default is 300 KB. SMTP TLS handshake details	Retention. Default is 14 DAYS.

Settings will be ignored for any log in the list above not enabled on the Interface Settings tab. When a log reaches the Max Size limit, it will be rotated and tagged with a timestamp. The Retention period determines how long rotated logs are kept before they are automatically deleted.

Unified2 Log Limit

32

Log file size limit in megabytes (MB). Default is 32 MB. This sets the maximum size for a unified2 log file before it is rotated and a new one created.

Unified2 Archived Log Retention Period

7 DAYS

Choose retention period for archived Barnyard2 binary log files. Default is 7 days. When file capture and store is enabled, Suricata captures downloaded files from HTTP sessions and stores them, along with metadata, for later analysis. This setting determines how long files remain in the File Store folder before they are automatically deleted.

Captured Files Storage Limit

1496

File Store captured files storage limit in megabytes (MB). Initial default value is 60% of the Log Directory Size Limit parameter configured above. This sets the maximum storage limit (disk utilization) for captured files. When this limit is reached, older files will be purged to reduce disk consumption below the configured limit. Entering zero disables this check and allows unlimited storage.

Captured Files Retention Period

7 DAYS

Choose retention period for captured files in File Store. Default is 7 days. When file capture and store is enabled, Suricata captures downloaded files from HTTP sessions and stores them, along with metadata, for later analysis. This setting determines how long files remain in the File Store folder before they are automatically deleted.

Captured TLS Certs Retention Period

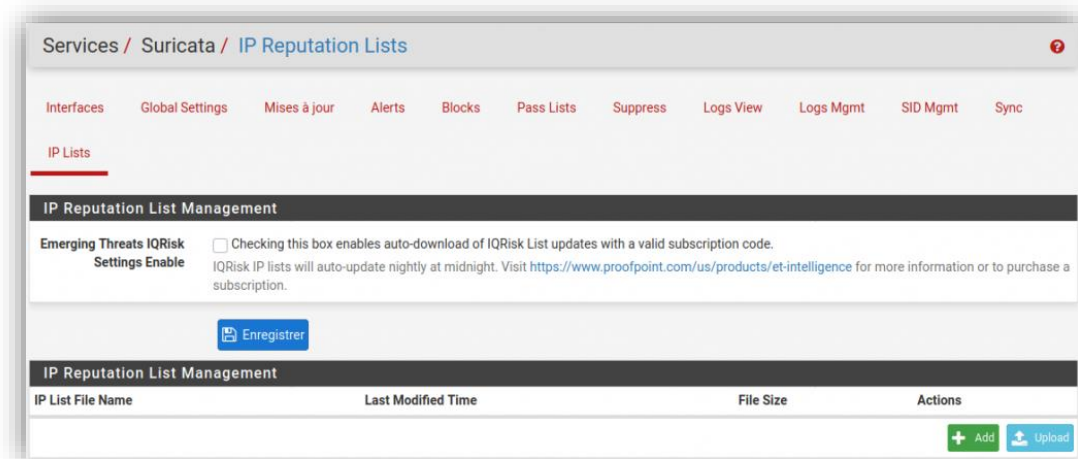
7 DAYS

Choose retention period for captured TLS Certs. Default is 7 days. When custom rules with tls.store are enabled, Suricata captures Certificates, along with metadata, for later analysis. This setting determines how long files remain in the Certs folder before they are automatically deleted.

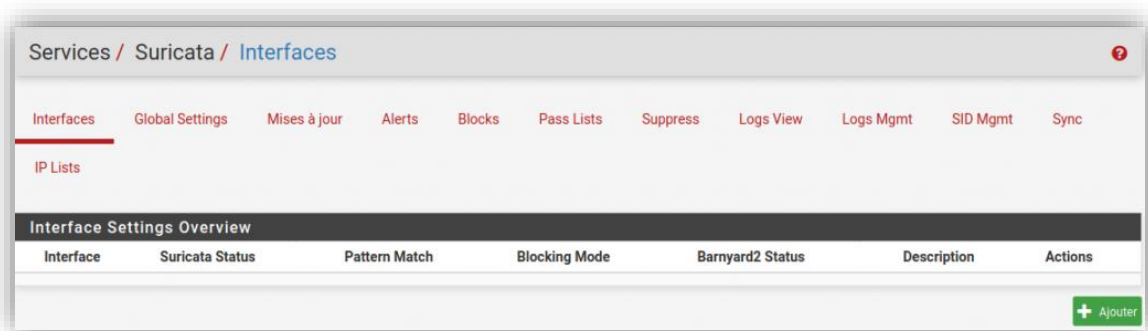
Enregistrer

La dernière partie à voir avant la configuration de l'interface est IP Lists. C'est à partir d'ici qu'on peut gérer une liste de réputation d'IP. Il y a deux options :

- Emerging Threat IQRisk : le téléchargement est automatique par contre il nécessite un abonnement payant.
- IP Reputation List Management : on peut ajouter "à la main" des fichiers (csv) contenant des listes d'adresses IP. Le fichier doit avoir un format particulier voir ici. Il faudra aussi renouveler régulièrement ce fichier. Voici une url qui permet de récupérer une liste en cliquant sur download local copy firehol.



Nous allons voir comment configurer une interface dans Suricata. C'est à cet endroit que nous disons à Suricata de fonctionner sur une ou plusieurs interfaces. Nous pouvons également personnaliser la configuration.



On clique sur Ajouter.

Dans WAN paramètres, on renseigne :

- Activer : on coche la case
- Interface : L'interface sur laquelle on veut que Suricata fonctionne
- Description : description

Le reste peut être laissé par défaut. Puis il faut enregistrer.

Performance and Detection Engine Settings	
Run Mode	AutoFP Choose a Suricata run mode setting. Default is "AutoFP" and is the recommended setting for most cases. "Workers" uses multiple worker threads, each of which single-handedly processes the packets it acquires (i.e., each thread runs all thread modules). "Single" uses only a single thread for all operations on a packet and is intended for use only in testing or development instances.
Max Pending Packets	1024 Enter number of simultaneous packets to process. Default is 1024. This controls the number simultaneous packets the engine can handle. Setting this higher generally keeps the threads more busy. The minimum value is 1 and the maximum value is 65,000. Warning: Setting this too high can lead to degradation and a possible system crash by exhausting available memory.
Detect-Engine Profile	Moyen Choose a detection engine profile. Default is Medium. MEDIUM is recommended for most systems because it offers a good balance between memory consumption and performance. LOW uses less memory, but it offers lower performance. HIGH consumes a large amount of memory, but it offers the highest performance.
Pattern Matcher Algorithm	Auto Choose a multi-pattern matcher (MPM) algorithm. Auto is the default, and is the best choice for almost all systems. Auto will use hyperscan if available.
Signature Group Header MPM Context	Auto Choose a Signature Group Header multi-pattern matcher context. Default is Auto. AUTO means Suricata selects between Full and Single based on the MPM algorithm chosen. FULL means every Signature Group has its own MPM context. SINGLE means all Signature Groups share a single MPM context. Using FULL can improve performance at the expense of significant memory consumption.
Inspection Recursion Limit	3000 Enter limit for recursive calls in content inspection code. Default is 3000. When set to 0 an internal default is used. When left blank there is no recursion limit.
Delayed Detect	☐ Suricata will build list of signatures after packet capture threads have started. Default is Not Checked.
Promiscuous Mode	☒ Suricata will place the monitored interface in promiscuous mode when checked. Default is Checked.
Interface PCAP Snaplen	1518 Enter value in bytes for the interface PCAP snaplen. Default is 1518. This parameter is only valid when IDS or Legacy Mode IPS is enabled. This value may need to be increased if the physical interface is passing VLAN traffic and expected alerts are not being received.

Dans WAN categories, nous cochons les packs de règles que l'on souhaite activer.

Suricata IDS / Interface WAN - Categories

Interfaces

Global Settings

Mises à jour

Alerts

Blocks

Pass Lists

Suppress

Logs View

Logs Mgmt

SID Mgmt

Sync

IP Lists

WAN Paramètres

WAN Categories

WAN Règles

WAN Flow/Stream

WAN App Parsers

WAN Variables

WAN Barnyard2

WAN IP Rep

Automatic flowbit resolution

Resolve Flowbits

☒ Auto-enable rules required for checked flowbits
Default is Checked. Suricata will examine the enabled rules in your chosen rule categories for checked flowbits. Any rules that set these dependent flowbits will be automatically enabled and added to the list of files in the interface rules directory.

View rules

View

Click to view auto-enabled rules required to satisfy flowbit dependencies

Note: Auto-enabled rules generating unwanted alerts should have their GID:SID added to the Suppression List for the interface.

Select the rulesets (Categories) Suricata will load at startup

Category is auto-enabled by SID Mgmt conf files

Category is auto-disabled by SID Mgmt conf files

Select All

Unselect All

Save

Activé	Ruleset: Snort GPLv2 Community Rules
☒	Snort GPLv2 Community Rules (Talos-certified)

Ruleset: ET Open Rules

Snort Rules are not enabled.

☒	emerging-activex.rules
☒	emerging-adware_pup.rules
☒	emerging-attack_response.rules
☒	emerging-botcc.portgrouped.rules
☒	emerging-botcc.rules
☒	emerging-chat.rules
☒	emerging-ciarmy.rules
☒	emerging-coinminer.rules
☒	emerging-compromised.rules

26

Dans WAN Règles, on peut consulter les règles contenues dans les packs que nous avons activés dans WAN Categories.

Suricata / Interface WAN / Rules: app-layer-events.rules

Interfaces Global Settings Mises à jour Alerts Blocks Pass Lists Suppress Logs View Logs Mgmt SID Mgmt Sync

IP Lists

WAN Paramètres WAN Categories **WAN Règles** WAN Flow/Stream WAN App Parsers WAN Variables WAN Barnyard2 WAN IP Rep

Available Rule Categories

Catégorie: app-layer-events.rules [View All](#)

Select the rule category to view and manage.

Rule Signature ID (SID) Enable/Disable Overrides

SID Actions [Apply](#) [Reset All](#) [Reset Current](#) [Disable All](#) [Enable All](#)

When finished, click APPLY to save and send any SID state/action changes made on this tab to Suricata.

Rules View Filter

Rule Signature ID (SID) Enable/Disable Overrides

Legend: Default Enabled Enabled by user Auto-enabled by SID Mgmt Action/content modified by SID Mgmt Rule action is alert Rule contains noalert option
 Default Disabled Disabled by user Auto-disabled by SID Mgmt

État	Action	GID	SID	Proto	Source	SPort	Destination	DPort	Message
		1	2260000	ip	any	any	any	any	SURICATA Applayer Mismatch protocol both directions
		1	2260001	ip	any	any	any	any	SURICATA Applayer Wrong direction first Data
		1	2260002	ip	any	any	any	any	SURICATA Applayer Detect protocol only one direction
		1	2260003	ip	any	any	any	any	SURICATA Applayer Protocol detection skipped
		1	2260004	tcp	any	any	any	any	SURICATA Applayer No TLS after STARTTLS
		1	2260005	tcp	any	any	any	any	SURICATA Applayer Unexpected protocol

Category Rules Summary

Total Rules: 6 Default Enabled: 6 Default Disabled: 0 User Enabled: 0 User Disabled: 0 Auto-Managed: 0

En cliquant sur le bouton État, on peut désactiver une règle si elle génère trop de faux positifs.

Rule State Selection

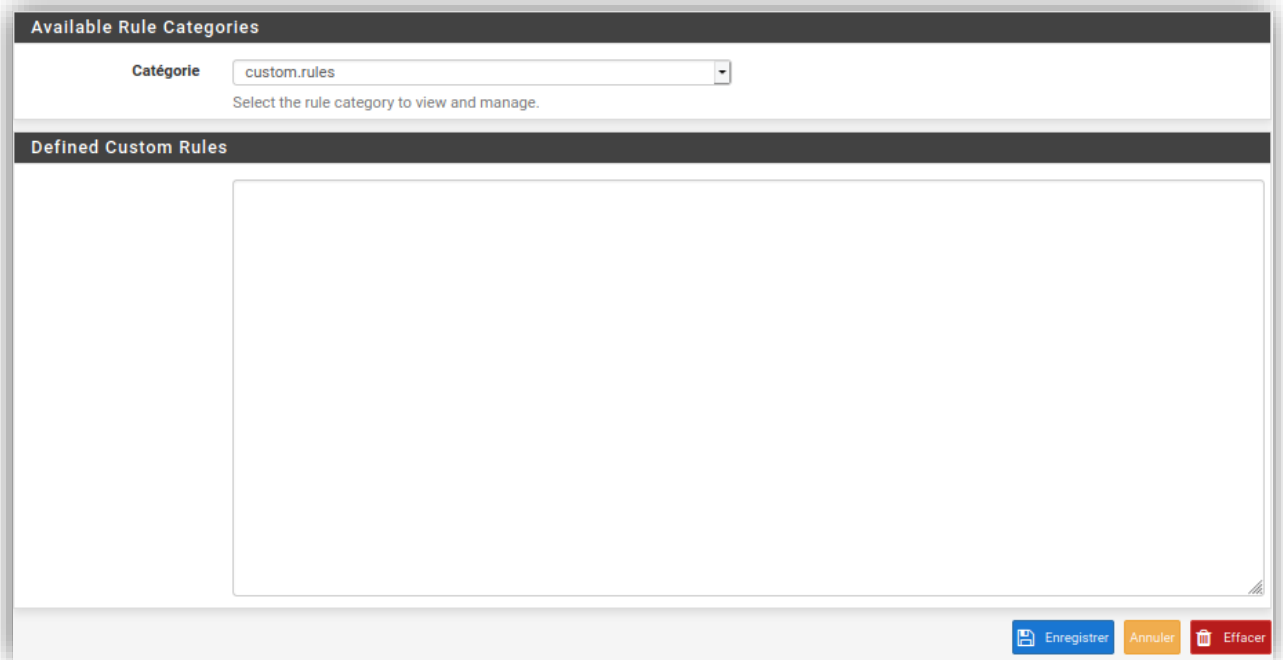
Choose desired rule state from selections below:

☐ Default ☒ Enabled ☐ Disabled

Choosing 'Default' will return the rule state to the original state specified by the rule package author.

[Enregistrer](#) [Annuler](#)

Et enfin si on sélectionne la catégorie custom.rules, nous pouvons écrire nos propres règles.



On clique sur WAN IP Rep si on souhaite activer la réputation IP.

On renseigne :

- Activer : coche la case
- Assign Catégories File : le fichier categories.txt
- Assign IP Réputation Lists : le fichier contenant les ips

Pour démarrer Suricata, il faut sur le bouton bleu "Start suricata on this interface".

Nous allons ensuite faire la création d'une liste d'IP réputation.

Pour ce faire, nous allons utiliser un outil fourni par AlienVault-OTX qui est une plateforme de Threat Intelligence Open Source.

Les outils de threat intelligence permettent de recueillir des informations sur les menaces et les vulnérabilités qui pourraient affecter l'entreprise. Les analystes de sécurité peuvent utiliser ces informations pour évaluer les risques et pour prendre des mesures préventives en conséquence.

AlienVault-OTX est une base de données massive d'informations sur les menaces ouvertes en collaboration avec des milliers d'organisations à travers le monde. Elle permet de partager des observables liés aux attaques telles que des IP compromettes, domaines, fichiers malveillants.



Les membres de la communauté peuvent alimenter OTX en y ajoutant des observables qu'ils détectent lors d'attaques sur leurs systèmes. Ces observables sont alors mis à la disposition de tous afin que chacun puisse mieux détecter et bloquer les menaces similaires.

Cet outil s'appelle OTX-Suricata. Pour l'utiliser, il vous faudra une clé API fournie lorsque vous vous inscrivez sur la plateforme.

Il permet de générer plusieurs choses :

- Le fichier categories.txt pour l'ip reputation
- Le fichier contenant les ips
- La règle suricata permettant l'utilisation de l'ip reputation
- Des fichiers contenant des hashes de malwares
- Des règles de détection se basant sur ces fichiers

Le script et les explications sur l'utilisation sont [ici](#).

Voici comment l'utiliser sur une machine Ubuntu :

```
sudo apt install python-pip
pip install OTXv2
python surcata.py --key clé_API --destination-directory destination_dossier
```

Maintenant nous ajoutons les fichiers categories.txt et reputation.list.

Dans Services, Suricata, IP lists puis on clique sur Upload, Parcourir puis Téléverser.

The screenshot shows the 'Services / Suricata / IP Reputation Lists' page. At the top, there's a navigation bar with links: Interfaces, Global Settings, Mises à jour, Alerts, Blocks, Pass Lists, Suppress, Logs View, Logs Mgmt, SID Mgmt, and Sync. Below this is a sub-header 'IP Lists'. The main section is titled 'IP Reputation List Management'. It includes a checkbox for 'Emerging Threats IQRisk Settings Enable' with a note about auto-updates. Below this is a table with columns: IP List File Name, Last Modified Time, File Size, and Actions. The table lists two files: 'categories.txt' (45 B) and 'reputation.list' (7 KIB), both modified on Jun-29 2020 at 5:36 pm. Below the table is a file selection area with a 'Parcourir...' button and a message 'Aucun fichier sélectionné.' There are 'Téléverser' and 'Fermer' buttons. At the bottom right, there are '+ Add' and 'Upload' buttons.

IP List File Name	Last Modified Time	File Size	Actions
categories.txt	Jun-29 2020 5:36 pm	45 B	
reputation.list	Jun-29 2020 5:36 pm	7 KIB	

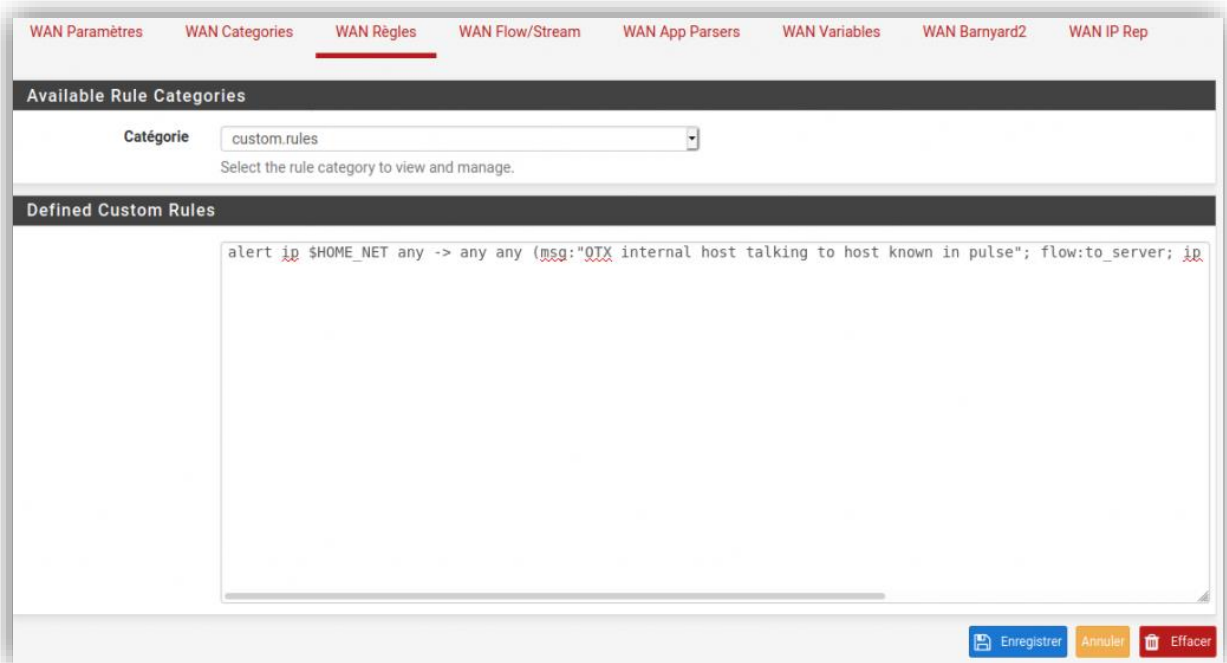
Dans Interfaces et sur la ligne WAN, nous cliquons sur le crayon dans Actions. Puis WAN IP Rep.

The screenshot shows the 'WAN IP Rep' configuration page. It has a navigation bar with links: WAN Paramètres, WAN Categories, WAN Règles, WAN Flow/Stream, WAN App Parsers, WAN Variables, WAN Barnyard2, and WAN IP Rep. The main section is titled 'IP Reputation Configuration'. It includes a checkbox for 'Activer' (checked) with a note 'Use IP Reputation Lists on this interface. Default is NOT Checked.' Below this are three input fields: 'Host Memcap' (33554432), 'Host Hash Size' (4096), and 'Host Preallocations' (1000), each with a description and a 'Min' value. Below these is a table titled 'Assign Categories File' with columns: Categories Filename, Modification Time, and Action. The table lists 'categories.txt' with a modification time of Jun-29 2020 5:36 pm and a 'Supprimer' button. Below this is a table titled 'Assign IP Reputation Lists' with columns: IP Reputation List Filename, Modification Time, and Action. The table lists 'reputation.list' with a modification time of Jun-29 2020 5:36 pm and a 'Supprimer' button. At the bottom right, there are '+ Ajouter' buttons for both tables.

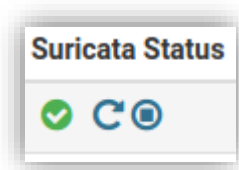
Categories Filename	Modification Time	Action
categories.txt	Jun-29 2020 5:36 pm	Supprimer

IP Reputation List Filename	Modification Time	Action
reputation.list	Jun-29 2020 5:36 pm	Supprimer

Cliquer sur Wan Règles et choisir la Catégorie custom.rules et nous prenons la règle présente dans le fichier otx_iprep.rules :

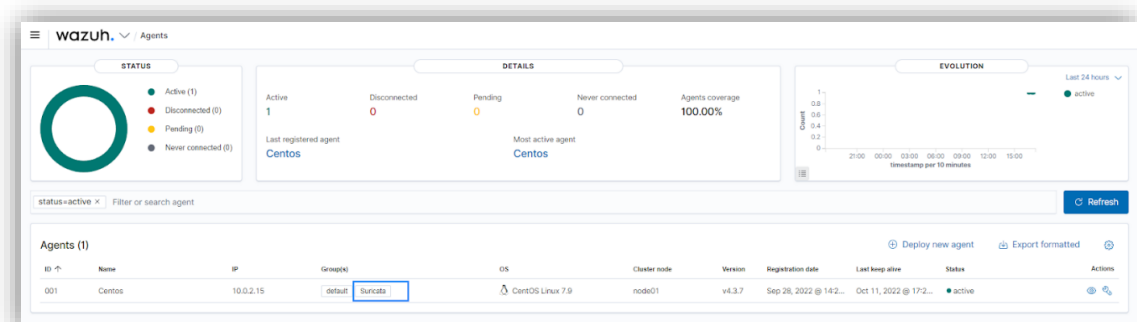


L'installation d'AlienVault-OTX est maintenant terminer.



Et pour finir, il reste à intégrer Suricata dans Wazuh. Et c'est tout simple, il suffit de créer un agent sur Wazuh et le faire installer sur Suricata.

Et les alertes Suricata remonte bien sur Wazuh :



d. Mesures de prévention :

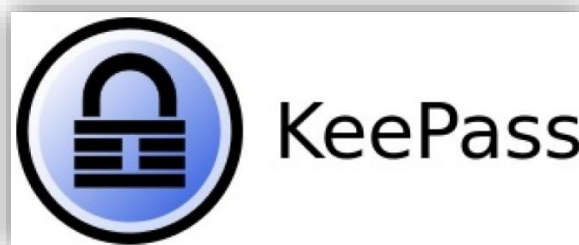
Le SOC a également mis en place des mesures de prévention pour protéger les systèmes d'information d'AudioProthèse+ contre les attaques informatiques futures. Cela inclut des activités telles que la surveillance des vulnérabilités, des mécanismes d'authentification forte, ainsi que la formation des employés à la sécurité de l'information.

Les solutions de protection des endpoints sont des logiciels de sécurité installés sur les ordinateurs, les smartphones et les tablettes des utilisateurs finaux.

Ces outils permettent de détecter et de bloquer les menaces telles que les virus, les malwares et les ransomwares, ainsi que de gérer les politiques de sécurité sur les endpoints.

KeePass est un gestionnaire de mots de passe open-source conçu pour aider les utilisateurs à stocker et gérer leurs mots de passe de manière sécurisée. Il utilise un cryptage robuste pour protéger les informations de connexion, garantissant que les mots de passe sont accessibles uniquement à l'utilisateur via un mot de passe maître unique. KeePass permet de créer des bases de données de mots de passe, où chaque entrée peut contenir des informations telles que le nom d'utilisateur, le mot de passe, l'URL du site web, et des notes supplémentaires.

L'un des principaux avantages de KeePass est sa flexibilité : il est compatible avec diverses plateformes et propose des extensions et des plugins pour étendre ses fonctionnalités. De plus, en étant open-source, il bénéficie d'une transparence et d'une sécurité accrues, puisque sa communauté d'utilisateurs peut examiner et améliorer son code.



Nous utilisons un EDR (Endpoint Detection and Response) comme CrowdStrike Falcon.

CrowdStrike est une entreprise de cybersécurité reconnue pour sa plateforme de protection des endpoints, notamment grâce à son produit phare, CrowdStrike Falcon.

Cette solution utilise l'intelligence artificielle pour détecter, prévenir et répondre aux attaques en temps réel, offrant une protection contre une large gamme de menaces informatiques telles que les malwares, les ransomwares et les activités de piratage sophistiquées.

Sa technologie de cloud computing lui permet de fournir des mises à jour de sécurité rapides et une surveillance continue, ce qui est essentiel pour les environnements d'entreprise dynamiques. En outre, CrowdStrike offre des services de renseignement sur les menaces et de réponse aux incidents, s'alignant ainsi sur une approche globale de la sécurité.

informatique. Sa réputation et son efficacité ont fait de CrowdStrike un choix populaire parmi les entreprises cherchant à renforcer leur posture de sécurité.



e. Rapports de sécurité :

La mise en place d'un rapport de sécurité quotidien est primordiale pour assurer une bonne gouvernance de la sécurité des systèmes d'information. En effet, disposer d'une visibilité journalière sur l'état de la sécurité permet de détecter rapidement toute anomalie ou événement anormal qui pourrait indiquer une attaque ou une faille de sécurité.

L'analyse quotidienne consolidée des logs et alertes issue des différents outils de surveillance (firewall, IDS, SIEM, antivirus etc.) offre une supervision continue du niveau de sécurité. Elle permet également d'identifier plus facilement d'éventuelles tendances, comme une activité malveillante répétée qui passerait inaperçue avec des rapports moins fréquents. De plus, la remontée d'information quotidienne auprès de la direction assure une bonne gouvernance en matière de sécurité des systèmes.

Enfin, les rapports quotidiens répondent aux exigences de certains standards comme ISO 27001, qui préconisent une surveillance régulière des événements de sécurité. En résumé, un rapport quotidien est indispensable pour une détection anticipée des menaces et incidents, et un pilotage efficace de la stratégie de sécurité.

Nous utiliserons Wazuh pour créer des rapports de sécurité. Pour être exact, un rapport quotidien, tous les jours à la même heure.

Voici donc les étapes pour configurer Wazuh afin qu'il envoie un rapport quotidien à 7h :

Activer la génération de rapport dans le fichier de configuration :

```
/var/ossec/etc/ossec.conf
```

Décommenter la section <reports> :

```
<reports> <active>yes</active> </reports>
```

Ajouter dans <reports_configuration> :

```
<reports_configuration>  
<report_format>html</report_format>  
<merge_reports>yes</merge_reports>  
<send_report>  
<day>everyday</day>  
<time>07:00</time>  
</send_report>  
</reports_configuration>
```

Ajouter dans <reports_email> les adresses mail des destinataires du rapport

Et nous finissons par redémarrer le service Wazuh :

```
systemctl restart wazuh-manager
```

Un rapport récapitulatif sera désormais généré et envoyé par mail quotidiennement à 07h00.

f. Forensique

Les outils forensiques sont des ressources précieuses pour les équipes de sécurité opérant au sein d'un Security Operation Center (SOC). En effet, lorsqu'un incident est détecté, ces outils permettent de mener des investigations approfondies sur les systèmes et réseaux concernés. Ils recueillent ainsi de précieuses preuves numériques qui peuvent être analysées pour retracer avec précision le déroulement de l'attaque et en identifier les auteurs.

Cela s'avère essentiel aussi bien pour assurer une riposte rapide que pour des besoins d'attribution et d'expertises légales. De plus, la reconstitution forensique post-incident aide à mieux comprendre les techniques employées et à adapter en conséquence les mesures de défense. Les outils forensiques appuient également la capitalisation des retours d'expérience pour améliorer les procédures du SOC.

Enfin, certains peuvent identifier des vulnérabilités exploitées ou de nouvelles menaces émergentes, nourrissant ainsi la veille technique menée par le SOC. Grâce à leurs capacités d'investigation poussée, les outils forensiques constituent donc un atout majeur pour les équipes en charge de la sécurité des systèmes d'information.

Nous utiliserons 2 outils pour améliorer notre SOC : Autopsy et Volatility

Autopsy est un outil open source dédié à la forensique numérique. Interfacé de manière ergonomique, il permet d'exploiter efficacement les fonctionnalités avancées de The Sleuth Kit au niveau des blocs disques.

Les analystes SOC peuvent ainsi examiner en détail les médias de stockage compromis lors d'incidents, à travers des éléments clés comme les timelines d'activité retraçant précisément les événements, ou l'analyse des logs et fichiers révélant des activités suspectes.



Sa facilité d'utilisation associée à des capacités forensiques poussées en fait un atout majeur pour mener les investigations techniques approfondies requises par un SOC, dans le but de comprendre les faits, recueillir des preuves et attribuer les attaques.

La reconstruction détaillée des événements guide efficacement les enquêtes, tandis que son ergonomie permet de traiter les volumes d'analyse indispensables au bon fonctionnement d'un SOC. Autopsy constitue donc un outil incontournable pour les équipes de réponse aux incidents.

Volatility est un outil open source majeur permettant la forensique sur mémoire vive. Il offre aux analystes SOC la capacité d'analyser les dump de RAM de systèmes compromis afin d'y détecter des processus et artefacts malveillants en cours d'exécution.

Grâce à ses fonctionnalités poussées, Volatility permet de reconstituer précisément l'état d'un système au moment de l'acquisition mémoire. Il est ainsi possible de retracer la chronologie précise des événements et de comprendre le comportement d'attaques au niveau du système d'exploitation.



Ces capacités d'investigation approfondie au niveau de la mémoire vive s'avèrent critiques pour les analystes chargés de répondre aux incidents dans le cadre de leur mission de remédiation et d'attribution.

De par sa facilité d'emploi et la qualité de ses résultats, Volatility est un outil incontournable pour tout SOC souhaitant disposer d'une solution performante de forensic memory forensics lors de ses enquêtes techniques post-incident.

D. Formation des équipes de sécurité au maintien d'un SOC

La formation continue des analystes au sein d'un Centre des Opérations de Sécurité (SOC) est essentielle pour maintenir leur compétence face aux évolutions techniques et menaces de sécurité. Cette formation devrait inclure plusieurs aspects clés :

- **Formation Technique** : Formation sur l'installation, la configuration et l'administration des outils principaux du SOC tels que SIEM, IDS/IPS, SOAR, et protection des endpoints. Cette formation permet aux analystes de maîtriser le fonctionnement et la maintenance de ces outils.
- **Analyse de Logs et Corrélation d'Événements** : Une formation pratique sur l'utilisation du SIEM pour l'analyse des logs et la corrélation d'événements est cruciale, tout comme la formation sur l'utilisation du SOAR pour l'investigation et la réponse aux incidents.
- **Interprétation des Alertes de Sécurité** : Les analystes doivent apprendre à interpréter les alertes de sécurité et prendre des décisions appropriées en matière de réponse, comme le blocage, la collecte de preuves, ou l'escalade de l'incident.
- **Techniques d'Analyses Forensiques** : Formation aux techniques d'analyse forensique et d'investigation numérique est nécessaire pour une enquête efficace sur les incidents.
- **Sensibilisation aux Tendances de Menaces** : Des sessions régulières de partage de renseignements sur les menaces et vulnérabilités actuelles sont importantes pour rester à jour.
- **Simulations d'Incidents** : Des ateliers pratiques de simulation d'incidents aident à la formation continue sur la détection, la réponse, et l'amélioration des processus.
- **Certifications Professionnelles** : Des certifications telles que EC-Council CHFI (pour l'analyse forensique), ISC2 SSCP (pour la sécurité des systèmes) et GIAC GASF (pour la gestion des incidents) sont cruciales pour valider les compétences des analystes du SOC.
- **Accompagnement Individuel** : Un tutorat ou coaching en sécurité peut contribuer au développement des compétences individuelles.

Ces éléments forment un cadre de formation complet, garantissant que les analystes du SOC restent alertes, compétents et efficaces dans la protection des systèmes d'information face à un paysage de menaces en constante évolution.

3. Conclusion

La mise en place d'un centre opérationnel de sécurité (SOC) externalisé pour AudioProthèse+ représente une avancée majeure dans la sécurisation de ses systèmes d'information. Grâce à la collaboration avec SUP DE VINCI, une institution de premier plan en matière de cybersécurité, AudioProthèse+ bénéficie d'une expertise technique et méthodologique de pointe pour la réalisation de ce projet ambitieux.

L'architecture du SOC, s'appuyant sur des solutions open-source comme Wazuh, TheHive, et Suricata, offre un environnement robuste et évolutif pour la surveillance, la détection des menaces, et la réponse aux incidents. L'adoption de ces outils, combinée à une formation approfondie des équipes de sécurité, permet d'assurer une gestion efficace et réactive face aux menaces informatiques.

Le projet met l'accent sur des aspects essentiels de la cybersécurité, tels que la surveillance en continu, la réponse automatisée aux incidents, la prévention des intrusions, et les mesures de prévention contre les cyberattaques. Par ailleurs, la mise en place de rapports de sécurité quotidiens et l'intégration de pratiques forensiques renforcent la capacité d'AudioProthèse+ à répondre rapidement et efficacement aux incidents de sécurité.

L'approche adoptée pour le projet est en parfaite adéquation avec les normes et réglementations actuelles, notamment l'ISO/IEC 27001 et le RGPD, garantissant ainsi la conformité et la sécurité des données. La formation continue des équipes, les simulations d'incidents, et les certifications professionnelles sont des éléments clés pour maintenir un niveau élevé de compétence au sein du SOC.

En conclusion, ce projet illustre l'importance d'une approche proactive et bien structurée dans la gestion de la cybersécurité. Il s'agit d'un exemple concret de la façon dont la collaboration entre les entreprises et les institutions spécialisées peut aboutir à des solutions de sécurité informatique efficaces, adaptées aux défis actuels et futurs dans ce domaine.